Threat model and privacy controls

Scope and assets

The website records attendance in a teacher's local browser. Protected assets include names, identifiers, enrollment snapshots, attendance, reasons, audit events, exports, backups and encryption keys. Students display self-asserted QR data. There is no school-account service, cloud synchronization or automated proof of physical presence.

Trust boundaries and controls

Forged ID or shared screenshot
Control: Roster validation and teacher identity verification
Remaining exposure: Unsigned QR data can be regenerated or relayed. Rotation and room challenge do not authenticate the person.

Duplicate callbacks or competing tabs
Control: Serialized scanner work and transactional attendance uniqueness
Remaining exposure: The interface refreshes on focus rather than providing collaborative synchronization.

Disputed earlier check-in
Control: Separate review events, original timestamps, required reasons and closure block
Remaining exposure: Teacher decisions and local actor identity are not independently authenticated.

Copied browser database
Control: AES-GCM authenticated encryption with record context and keyed indexes
Remaining exposure: Short numeric PINs permit offline guessing. Metadata and record relationships remain visible.

Compromised website code or unlocked device
Control: Reviewed dependencies, safe rendering, short plaintext lifetime, local locking
Remaining exposure: Malicious same-origin scripts or a device owner can read unlocked data and alter local application behavior.

Storage deletion or lost hardware
Control: Encrypted backups and validated atomic restoration
Remaining exposure: Browser persistence cannot prevent user deletion or device destruction. Unsaved writes are not recoverable guarantees.

Malicious CSV or export content
Control: Import validation, collision checks, text Excel cells, CSV formula neutralization
Remaining exposure: Exported files contain plaintext personal data and must follow institutional handling rules.

Unsafe network hosting
Control: HTTPS/localhost requirement, secure-context splash, cached assets
Remaining exposure: Initial loading and software updates depend on hosting integrity.

Cryptographic baseline

The requested implementation derives separate AES-GCM-256 and HMAC-SHA256 keys using PBKDF2-HMAC-SHA256 with 100,000 iterations and a random salt. Each encryption has a fresh 96-bit IV and authenticated record context. Keys are non-extractable browser objects, retained in memory while unlocked. Numeric PINs remain a deliberate compatibility limitation. Non-extractability does not stop malicious code from using a key while it is accessible.

Local application operations append audit events. They do not create independently tamper-proof evidence against a person controlling the browser or its stored database. Exported audit history must be interpreted with that limitation.

Institutional privacy work

Encryption does not establish compliance with RA 10173. Education-related information can be sensitive personal information. The institution must identify its processing basis and accountable parties, approve notices and access rules, define retention/deletion, handle student rights, establish incident reporting and assess personal teacher devices and exported records.

No claim is made that losing encrypted hardware automatically avoids a privacy incident or legal obligation. Assess the actual facts, key strength, device state and applicable institutional procedures with the responsible privacy officer.

Honest panel answers

Does rotation prevent screenshots? No. A screenshot can arrive within the acceptance window and unsigned payloads can be recreated. Teacher identity verification is part of the attendance procedure.

What happens after device theft? Stored private records are encrypted, but protection depends on PIN strength and whether the device or website was compromised or unlocked. Backups address availability. Incident handling follows institutional policy.

Why use a website? The implementation uses an HTTPS URL and cached resources across supported browsers. It avoids mandatory native-app installation. Initial preparation and actual browser testing remain necessary.

How are duplicates handled? A session/student has one attendance record. Deliberate rescans show prior attendance. A reasoned dispute records both times and requires resolution before closure.

What empirical performance result can be defended? Only results actually collected under the field protocol. No 45-device timing result has been measured in this implementation session.

References

National Privacy Commission, implementing rules:
https://privacy.gov.ph/implementing-rules%20regulations-data-privacy-act-2012/

OWASP cryptographic storage guidance:
https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html

WebKit storage policy: https://webkit.org/blog/14403/updates-to-storage-policy/